

HRMS Mobile — Authentication Flow

OTP-based login for the Flutter app · API base path `/api/v1/auth`

Temporary OTP (development): the OTP screen is always shown; the backend accepts **any 4-digit code** and sends **no SMS** (`OTP_MODE=development`). Switching to production needs **no app changes**.

```
Enter Mobile / Employee ID / Email
  | POST /api/v1/auth/login
  ▼
{ sessionId, otpRequired:true, otpLength:4 }      (no SMS in development)
  |
OTP screen (user types any 4 digits during development)
  | POST /api/v1/auth/verify-otp { sessionId, otp }
  ▼
{ accessToken, refreshToken, expiresIn, user{ ... } }
  |
Store tokens → call protected APIs with Authorization: Bearer <accessToken>
  | on HTTP 401 → POST /api/v1/auth/refresh { refreshToken }
  ▼
{ accessToken } (new) → retry the original request
```

Step by step

#	Action	Endpoint	Result
1	Submit identifier	POST /login	sessionId + otpLength
2	Enter OTP (any 4 digits in dev)	POST /verify-otp	accessToken + refreshToken + user
3	Call protected APIs	Authorization: Bearer token	data
4	On 401	POST /refresh	new accessToken
5	Logout	POST /logout	clear tokens

Identifiers accepted at login

mobile: 9876543210

employeeId: VE-AHM-001

email: abc@gmail.com

Authorization header

Authorization: Bearer <accessToken>

The same access token works for **every** protected HRMS endpoint, not just the auth routes.